

Cash, Drugs, and Guns: Why Your Safes Aren't Safe

Abstract: When Liberty Safe was found to have provided safe unlock codes to authorities, it made us wonder; how was it even possible for Liberty to do this? Our talk will cover the vulnerabilities we found and journey into the various families of locks made by SecuRam, the OEM of safe locks used by Liberty Safe and other Safe vendors.

Our exploration began with an “analog” lock from Liberty Safe but quickly expanded to SecuRam’s “digital” lock lines, where we found a debug port that allowed access to all firmware and data. Through this, we discovered that codes are stored on the externally accessible keypad, rather than securely inside the safe (as well as other issues).

These locks, deployed widely in consumer, and commercial safes at major retail chains exhibit vulnerabilities that enable opening them in seconds with a Raspberry Pi.

We invite you to our session to see us crack UL-certified High-Security Electronic Locks live!

Intro/Story Time

Who Are We?



Mark Omo

Director of Cat Herding

- Leads the an Engineering team
- Expert in hardware and embedded/product security
- Background in regulated device design in the Medical, Industrial, Aerospace, and Consumer market segments



James Rowley

Senior Security Engineer

- Leads security programs
- Expert in disassembly and embedded security
- Background in regulated device design in the Medical, Industrial, Aerospace, and Consumer market segments
- Generally considered to be a nice guy

The views and opinions expressed in this presentation are solely our own and do not necessarily reflect those of our employer or any affiliated organizations.

This work was conducted independently by us.

Remember this incident?

The New York Times

How a Company That Makes Gun Safes Angered Gun Owners

Liberty Safe faced intense criticism this week after it acknowledged that it had voluntarily given the F.B.I. the access code to a safe in response to a search warrant for a property.



Share full article



- During an FBI search on Aug. 30, 2023
- Liberty Safe gave the FBI an access code for a safe

(Liberty Safe has since changed it's policy)

Sources:

<https://www.nytimes.com/2023/09/08/business/liberty-safe-codes.html>

<https://www.locksmithledger.com/safes/news/53071785/liberty-safe-facing-backlash-over-giving-reset-code-to-fbi>

That got us thinking...

The New York Times

How a Company That Makes Gun Safes Angered Gun Owners

Liberty Safe faced intense criticism this week after it acknowledged that it had voluntarily given the F.B.I. the access code to a safe in response to a search warrant for a property.



Share full article

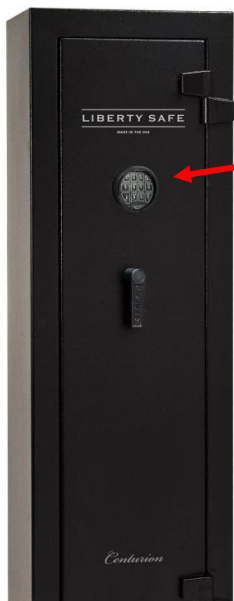
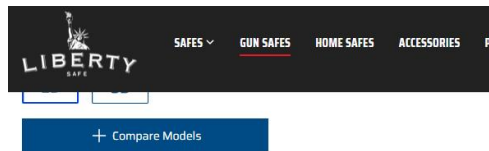


How does that even work?

How does the manufacturer even have this code?



Turns out Liberty Safe uses **Securam locks** Which are UL Certified High Security Safe Locks



Securam Toplit



Sources:

<https://www.libertysafe.com/blogs/the-vault/safe-locks-101>

<https://www.libertysafe.com/pages/securam-options>

Certificate of Compliance UL-US-2403300-1

Let's get one.



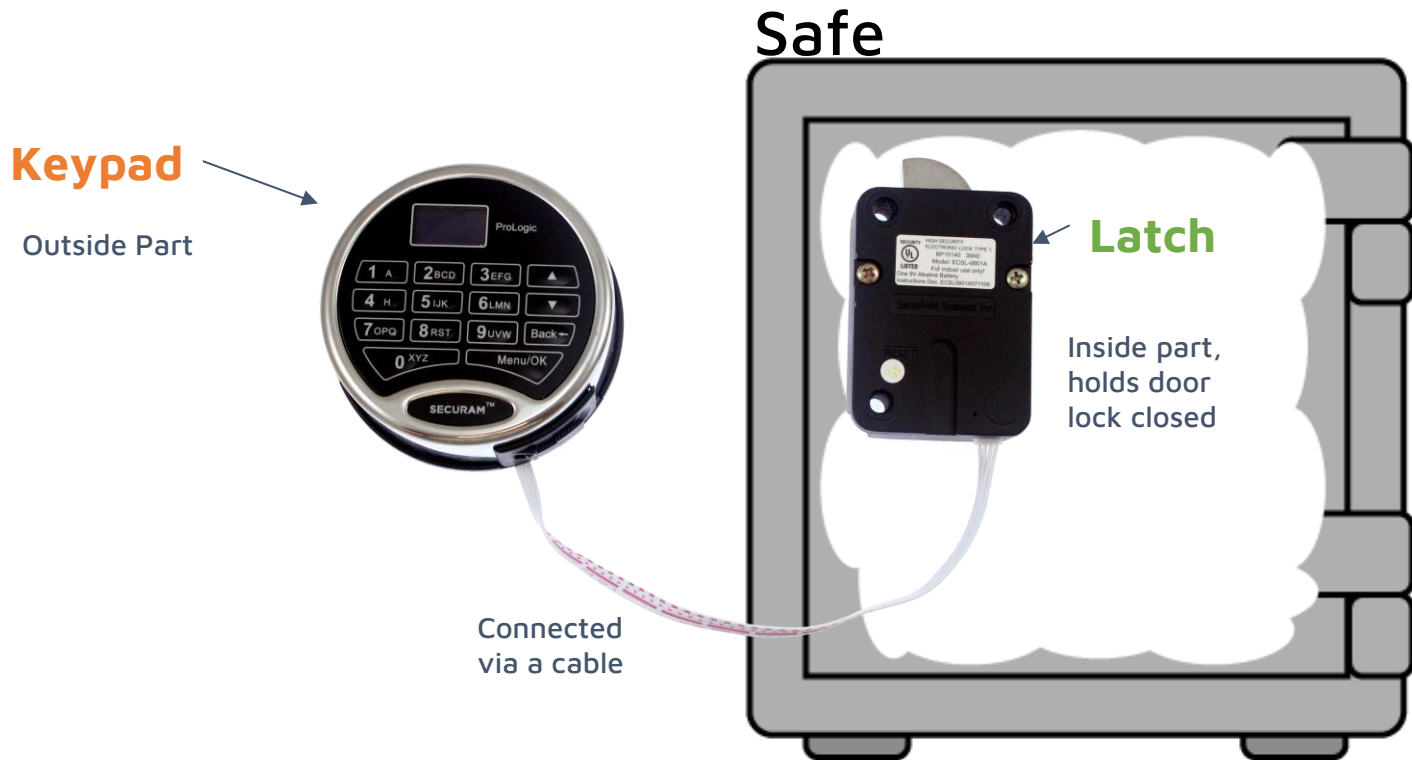
Delivered
Returns not accepted.

Safe Lock
US \$100.00

Ebay, the source of all things

Bought a **Liberty Safe TopLit**
(actually made by Securam)

Terminology: **Latch** vs. **Keypad**



Reverse Engineering TopLit

- Figuring out how to dump it
 - **Completely novel exploits** against processors and custom tooling
 - Hardwear.io talk last year on our novel FW dump exploit on the Renesas 78K0S/Kx1+ processor used in the latch
- **Manual reverse engineering**
 - Including creating a custom disassembler!
 - No Ghidra Support :(

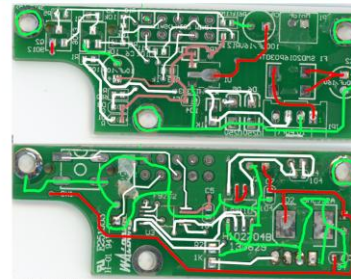


Powerline analysis to the rescue!

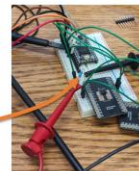
Quick PCB Reverse Engineering

Side note:
They labeled every component with a part number

Part is a
NEC Renesas
μPD78F9202



Information by
assumption?



Are there super secret backdoor codes?

Not really. There's just two codes:

- **Manager Code**

- Can change itself or the user code
- Can enable/disable user code
- Can't be disabled

- **User Code**

- The one & only code for the lock, from a user's perspective.
- User-facing documentation only describes this code.
- Can't modify manager code, can change itself but can't disable itself.

- **There are no other ways to open the lock**

```
static const struct nvdata __at(0x0E00) k_nv1 = {
    .wrong_count = 0x00,
    .code_manager = { // "111111"
        0x31, 0x31, 0x31, 0x31, 0x31, 0x31
    },
    .code_user = { // "123456"
        0x31, 0x32, 0x33, 0x34, 0x35, 0x36
    }
    .user_mode = UM_ENABLED, // = 0x01
    .digital_id = 0xFF,
    .lock_type = LT_ANALOG_A, // = 0xAA
    .digital_mode = 0xAA,
    .data_valid = 0xAA
}; // initial value in new lock
```

Sources:

SafeLogic Basic Series -MANAGER- Operating Instructions; Doc.No.:BM-EC0601A130919
Analysis of firmware from EL-0601-BM mfg'd in 2018 (S/N 41807201810293003049) (at C-68)

Who has the manager code?

- Safe vendors or independent locksmiths, such as Liberty Safe, typically set and withhold the manager code.
 - It provides an easy and non-destructive way to get back into a safe if a customer forgets their user code.
 - Of course, this makes one's security entirely reliant on trusting a third party to actually keep their manager code secure...
- Liberty Safe offers to delete the record of this for any concerned customer.
 - Unsure of other vendors' policies.
 - It can also be reset by resetting the latch.
 - (You should probably do this.)
- But, **not a technical vulnerability**, just a **management vulnerability**.
- They recommend this practice in some documents

Sources:

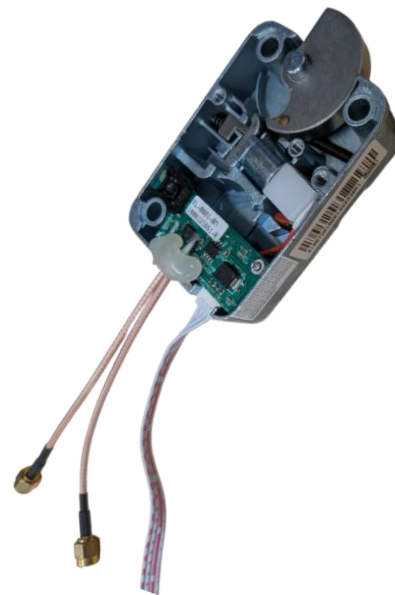
SafeLogic Basic Series -MANAGER- Operating Instructions; Doc.No.:BM-EC0601A130919

"In some instances the Manager Code and associated Operating Instructions are not issued to the End User. In this case, simply remove this insert from the Operating Instruction."

<https://www.libertysafe.com/pages/combination-removal>

TopLit/SafeLogic is... actually fine!

- After reverse engineering its whole firmware, we determined that in the SafeLogic operating mode, **we didn't identify any clear, exploitable security vulnerabilities!**
- Only gap is the use of a non-constant-time compare on the unlock code.
 - We were unable to exploit it even with best in class power analysis
 - Theoretical vulnerability, but in the best case scenario still a very slow method (five-minute time out).
- **But that's only true *in SafeLogic mode*, i.e., “analog mode”.**



Source:
 Analysis of firmware from EL-0601-BM mfg'd in 2018 (S/N 41807201810293003049)
 Note: this conclusion may not be applicable to other HW/FW versions.

Analog Vs. Digital

- Securam's docs describe the **SafeLogic** series as **"analog" locks**.
 - Button presses on the keypad are transmitted as analog voltage levels; the keypad has no smarts at all.
- Actuator firmware definitely has code paths for digital communication
- Turns out Securam has **"digital" locks** - the **ProLogic** and **ScanLogic series**.

Sources:

<https://securamsys.com/collections/lock-bodies>

ProLogic L01 Operation Instructions V1.02: https://support.securamsys.com/hc/en-us/article_attachments/12750832079131

Analysis of firmware from EL-0601-BM mfg'd in 2018 (S/N 41807201810293003049) (at C-966, C-251)

Reverse Engineering ProLogic

Digging into Securam's lineup

ProLogic looks interesting; let's look into it



ProLogic L02 is the **most popular model**

ProLogic Lock is the **Digital line** of locks

- This is the one we dig into
- ProLogic Locks are **also UL Certified** High Security Safe Locks

Turns out this was the start of a curse, we are now drowning in locks...



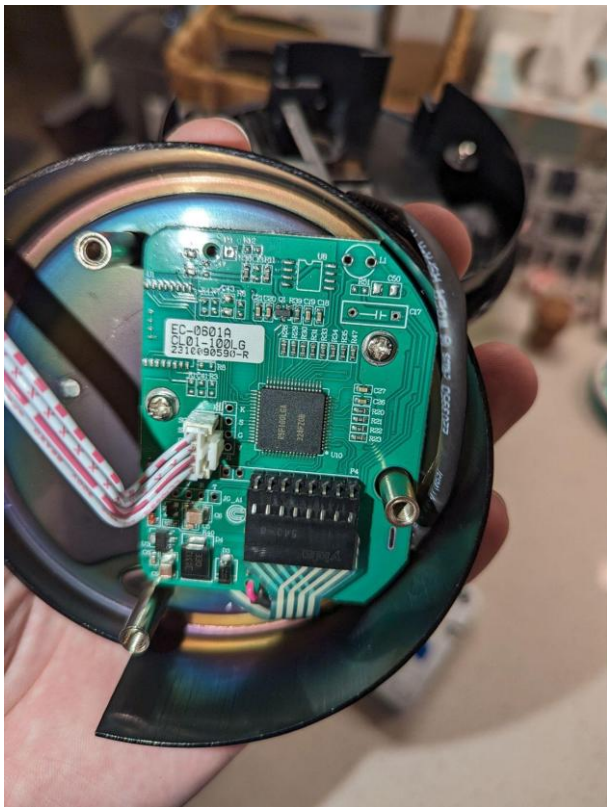
Some interesting facts...

- The latch has a “reset” button, **but it doesn't reset the codes** when a ProLogic keypad is used (vs. SafeLogic).
- ProLogic has a “recovery” mode; lets you call the factory and get a magic code, **this does reset the codes.**
- OEM claims “Encryption” and “Security”

Sources:

ProLogic L01 Operation Instructions V1.02: https://support.securamsys.com/hc/en-us/article_attachments/12750832079131

What's in here?



- It's a **Renesas RL78/G13**
- Turns out this is **in the PS4**
- The **gamer hackers already got this one**
 - Documented attacks to dump memory, get the debug port etc.
 - **The more widely a part is used, the more likely any flaws will be found.**
 - *Many thanks to fail0verflow!*

Sources:

<https://fail0verflow.com/blog/2018/ps4-syscon/>

Analysis of EC-0601A-CL01-100LG hardware mfg'd in **2023** (S/N 43427202310270005042)

Analysis of EC-0601A-CL02-100LG hardware mfg'd in **2022** (S/N 4320A302210141601040)

Reverse Engineering the Code

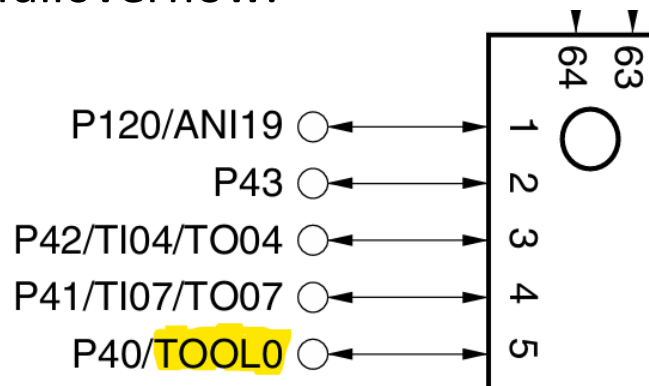
Sources for this section:

Primary firmware analysis of "V6.00211027" firmware from EC-0601A-CL02-100LG mfg'd in 2022 (S/N 4320A302210141601040)

Confirmed exploits on "V6.00211027" firmware from EC-0601A-CL01-100LG mfg'd in 2023 (S/N 43427202310270005042)

First, one must GET the code

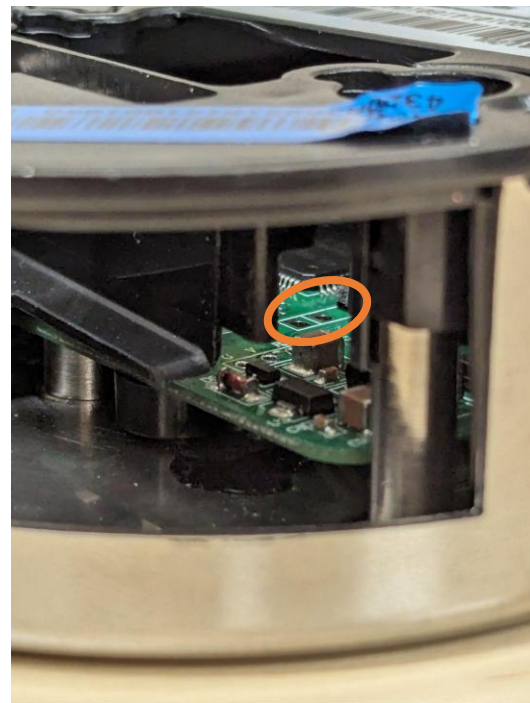
- The RL78/G13 has a combined flash programming and debug function accessible on the “TOOL” pin.
- Flash mode doesn’t have any read command, but **debug mode can be used** to upload a little program to RAM that **dumps everything**.
- The hard work of documenting the debug protocol and developing security bypasses was thankfully done by fail0verflow.
- Still, no reference implementation.
We’ll need to set all this up and figure out the right **glitching parameters**.



Easy physical access to debug port

Fortunately, the programming port, which is also the debug port, is very easy to access.

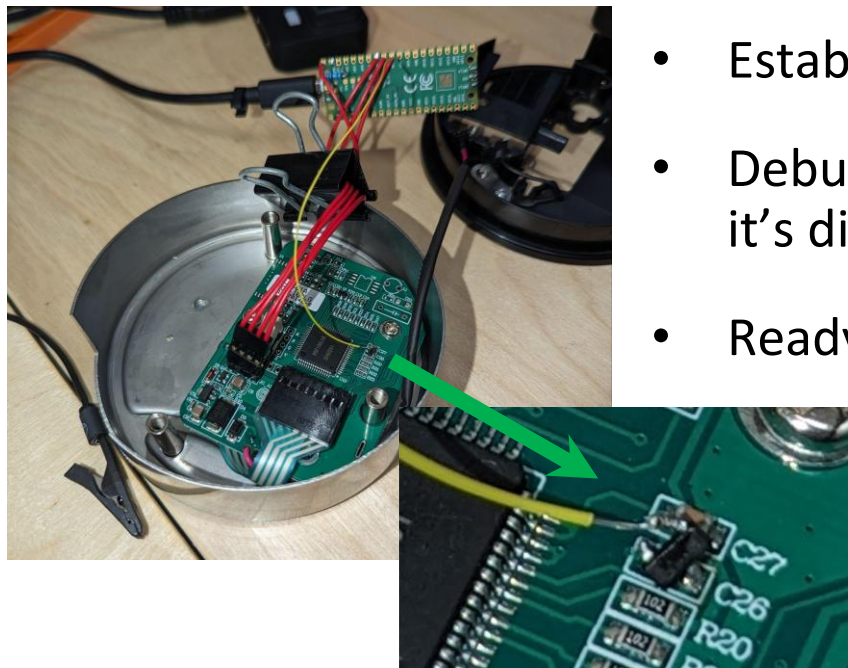
Can even get at it through the battery door!



Sources:

Pictured keypad is a Securam L02 manufactured Sep 26th 2022

Ready to dump!



very special capacitor

- Put crowbar FET in place of core voltage cap
- Established **basic comms with debug port**
- Debug commands **shouldn't work** because it's disabled, but can glitch past this.
- Ready to start glitching after entering debug mode...

We built a custom software stack for the Pi Pico to do this work.

Easier than it looked

- Well, the **debug mode commands immediately work**
 - Guess it *wasn't* disabled...
- We still **don't know the unlock code**, which must be provided to unlock full debug functionality.
 - But we might as well try all 0's.
- **Unlock code is 0000000000**



No glitches needed.

Source:
Analysis of "V6.00211027" firmware from EC-0601A-CL02-100LG
mfg'd in 2022 (S/N 4320A302210141601040)



Let's dig in to the code!



```
Listing: sr2_keypad.bin.2

*****
* FUNCTION *
*****
undefined __stdcall menu_change_code(byte which)
undefined A:1 <RETURN>
byte X:1 which
uint32_t Stack[-0xc... key
menu_change_code
...0060ba PUSH HL
XREF[4... menu_user_add:00006824(c),
sysmenu:00007ed5(c),
sysmenu:0000807e(c),
sysmenu:000080a7(c)
...0060bb PUSH AX
...0060bc SUBW SP,#
...0060be MOVW HL,SP
...0060c1 CALL !!oled_clear_main
undefined oled_clea...
...0060c5 MOVW AX,#s_..._000033dc
...0060c8 PUSH AX=>s_..._000033dc
...0060c9 MOVW AX,#s_..._000033e5
...0060cc CALL !!oled_2xctr_strings
void oled_2xctr_str...
```

```
Decompile: menu_change_code - (sr2_keypad.bin.2)
159 }
160 sVar5 = (short)((ushort)bStack_4 << 8) >> 6;
161 /* This decompilation sucks bu
162 ((uint32_t*)DFLData)[which]
163 passing the address of that
164 *(undefined2 *) (sVar5 + -0x2b5e) = CONCAT11(key.
165 *(undefined2 *) (sVar5 + -0x2b5c) = key._2_2_;
166 key._0_1_ = 1;
167 key._1_1_ = 0;
168 sVar5 = (short)((ushort)bStack_4 << 8) >> 6;
169 uVar3 = *(undefined2 *) (sVar5 + -0x2b5c);
170 enc_dec_code((uint32_t *) (((short)((ushort)bStack_4 << 8) >> 6) << 8) >> 6)
171 (uint32_t *) &tempCodeHigh,
172 CONCAT13((char)((ushort)uVar3 >> 8)
173 CONCAT12((char)uVar3,*(unc
174 if (bStack_4 == 0) {
175 DFLData.superCodeHigh._0_2_ = (undefined2)tempCodeHigh._0_2_
176 DFLData.superCodeHigh._2_2_ = tempCodeHigh._2_2_
177 }
178 else if (bStack_4 == 0x20) {
179 DFLData.encCodeHigh._0_2_ = (undefined2)tempCodeHigh._0_2_
180 DFLData.encCodeHigh._2_2_ = tempCodeHigh._2_2_
181 }
```

Type	Category	Description	Location	Label	Code Unit
Error	Bad Instruction	Failed to disassemble...	000080c3		?? ??
Error	Bad Instruction	Unable to resolve...	0000803e		?? ??
Error	Bad Instruction	Could not follow...	0000802b		?? ??
Error	Bad Instruction	Failed to disassemble...	00008032	%	da *
Error	Bad Instruction	Failed to disassemble...	00008010		?? ??
Note	IMPORTAIN		000060f4	CALL oled_...	
Note	recovery!		00008031	CALL oled_...	

Find some interesting things...

Where would you store the codes?

Safe

Keypad

Outside Part



Connected
via a cable



Latch

Inside part,
holds door
lock closed



What do you think they did?

Yep they put them on the outside

	00	01	02	03	04	05	06	07	08	09	0A	0B	0C	0D	0E	0F
000F1000	45	33	9C	B2	C4	C3	C3	1C	00	00	00	80	C6	52	68	E7
000F1010	30	5C	96	4E	CF	E8	83	0B	08	00	08	00	08	00	00	00
000F1020	00	00	00	00	01	00	00	00	00	00	00	00	FF	FF	01	01
000F1030	04	00	02	01	FF	FF	FF	01	11	00	01	00	00	00	00	00
000F1040	FF	00	06	02	7C	3D	00	00	A6	6A	2D	E1	31	5A	47	94
000F1050	85	1B	AF	68	2E	CB	D3	CD	C0	D9	6E	97	00	02	55	AA
000F1060	AA	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00
000F1070	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00

Super Code is Right Here
Stored in the Keypad



Source:
 Analysis of "V6.00211027" firmware from EC-0601A-CL01-100LG
 mfg'd in 2023 (S/N 43427202310270005042)
 Note: this may not be applicable to other HW/FW versions.

What about the *encryption*?

They said there was encryption...

What about Encryption?

- The super code **is stored encrypted**
 - Super Code is kind of like root
 - Encrypted with XXTEA (symmetric cipher) and a 128-bit key
- **How could we possibly decode it?**

	00	01	02	03	04	05	06	07	08	09	0A	0B	0C	0D	0E	0F
000F1000	45	33	9C	B2	C4	C3	C3	1C	00	00	00	80	C6	52	68	E7
000F1010	30	5C	96	4E	CF	E8	83	0B	08	00	08	00	08	00	00	00
000F1020	00	00	00	00	01	00	00	00	00	00	00	00	FF	FF	01	01
000F1030	04	00	02	01	FF	FF	FF	01	11	00	01	00	00	00	00	00
000F1040	FF	00	06	02	7C	3D	00	00	A6	6A	2D	E1	31	5A	47	94
000F1050	85	1B	AF	68	2E	CB	D3	CD	C0	D9	6E	97	00	02	55	AA
000F1060	AA	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00
000F1070	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00

Encryption key is stored here
(plus 96 bits of *static* key)

Source:
Analysis of "V6.00211027" firmware from EC-0601A-CL01-100LG
mfg'd in 2023 (S/N 43427202310270005042)
Note: this may not be applicable to other HW/FW versions.

ScanLogic Basic



- Doesn't even bother with encryption!
- Debug port unlocked on this model too!

	00	01	02	03	04	05	06	07	08	09	0A	0B	0C	0D	0E	0F	
000F1000	FF	FF	45	48	15	02	46	50	43	2D	31	38	30	38	2D	4D	..EH..FPC-1808-M
000F1010	61	69	6E	20	20	56	33	2E	30	30	32	32	30	36	31	37	ain V3.00220617
000F1020	20	20	56	31	2E	32	30	31	39	30	36	30	34	00	00	00	V1.20190604...
000F1030	00	01	00	3F	42	0F	00	74	60	8C	04	2B	87	10	04	...?B..t`...+....	
000F1040	01	00	00	999999				00	00	5C	DF	81	DF	00	FF	\.....	
000F1050	FF	FF	FF	999999				FF	FF	FF	FF	FF	FF	FF	FF		
000F1060	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF		
000F1070	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF		
000F1080	01	00	FF	5F	0D	00	FF	FF	FF	FF	FF	FF	FF	FF	FF	..._.....	
000F1090	FF	FF	876543				FF	FF	FF	FF	FF	FF	FF	FF	FF		
000F10A0	FF	FF	876543				FF	FF	FF	FF	FF	FF	FF	FF	FF		
000F10B0	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF		
000F10C0	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF		
000F10D0	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF		
000F10E0	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF		
000F10F0	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	44 57	DW	

Source:

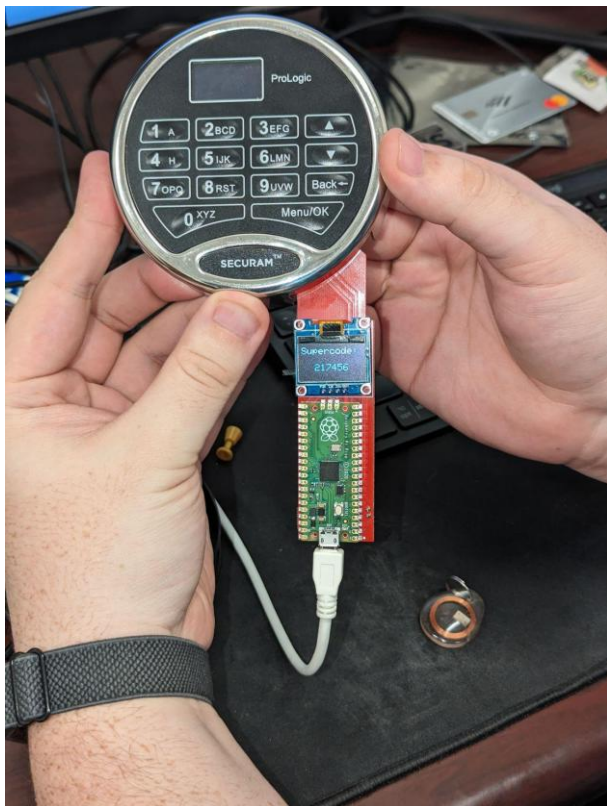
Analysis of dataflash from FPC-1808-v5 mfg'd in 2023 (S/N 51825392312220123051)

The Attack

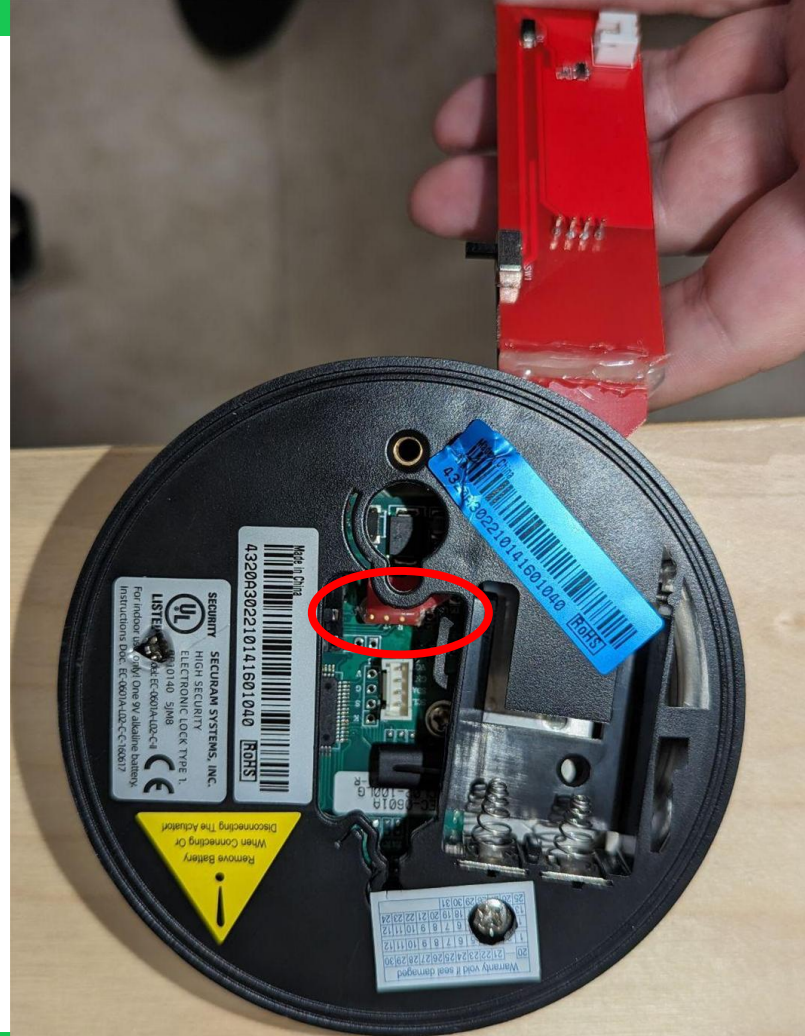
We built this
custom tool



It reaches way up in there



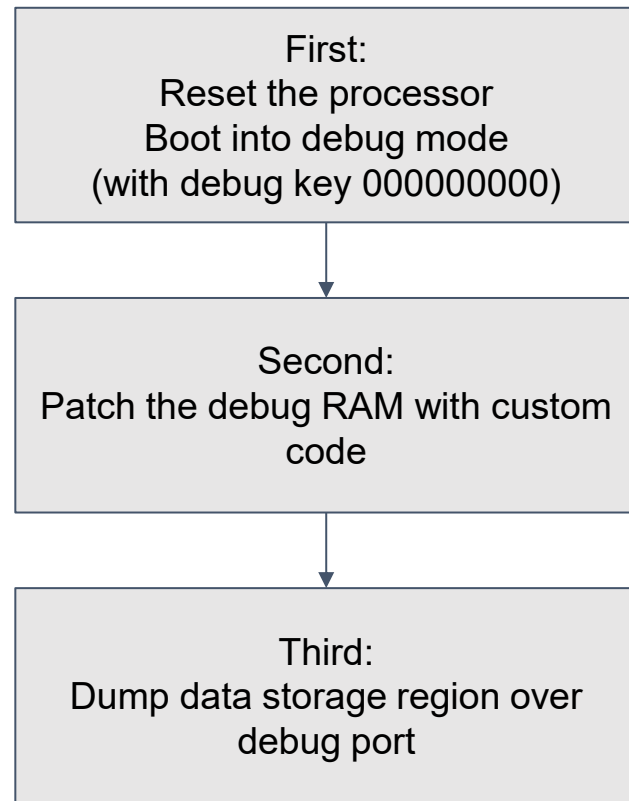
And connects to
the debug port



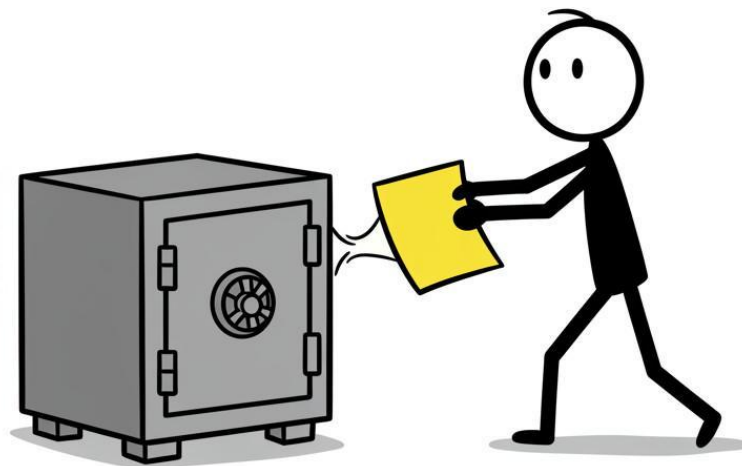
Goes through a **lengthy complex process**:

- Booting the processor in debugging mode
- Injecting a code blob
- Reading out the memory

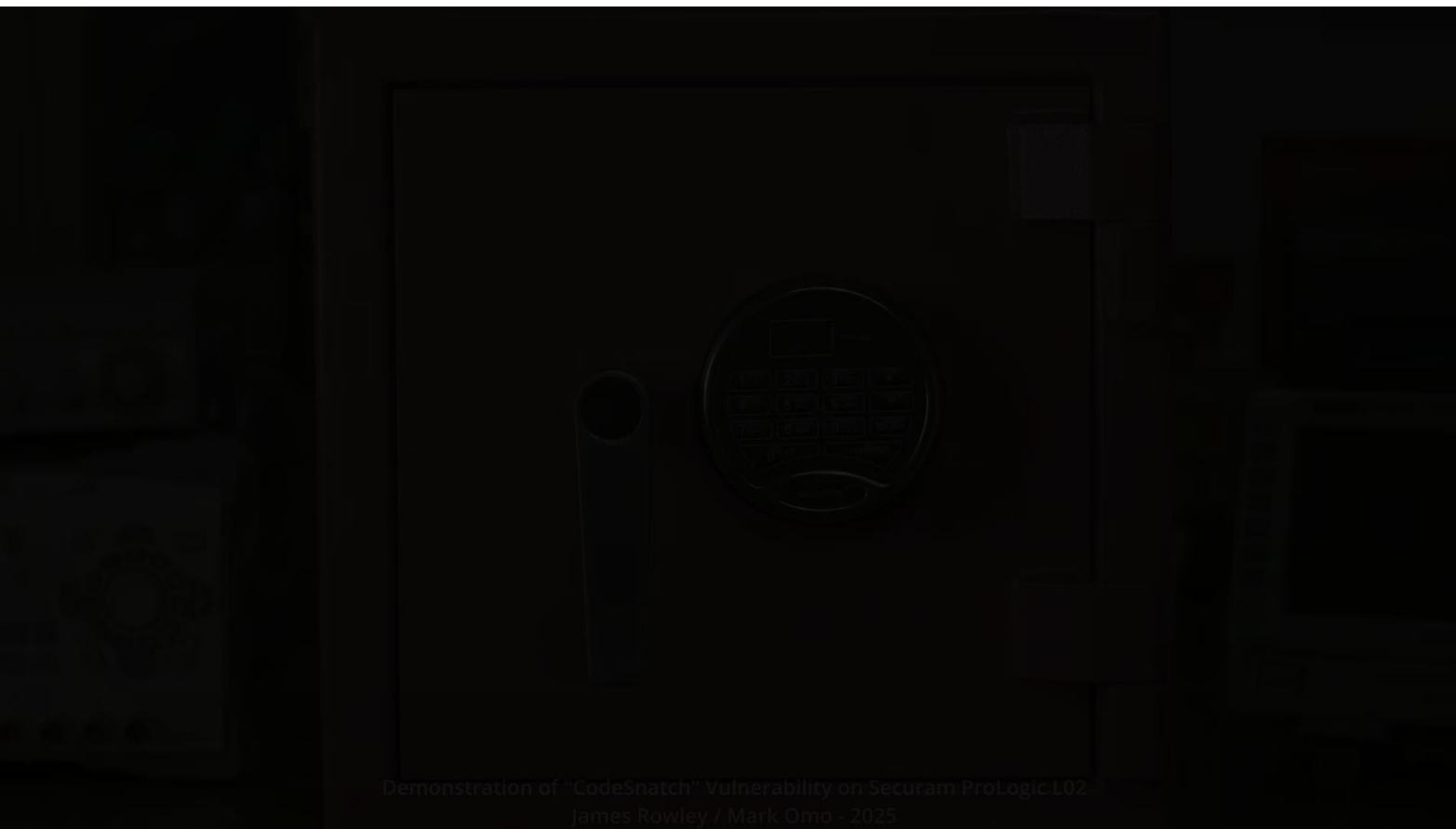
This takes 0.8s



We call this attack **CodeSnatch**



Demo Time!



Ok... but who uses these things?

Note: We have not purchased or tested locks from the following vendors, only identified that they sell the same models of locks we examined and found vulnerable to at least one attack.

Our attacks were tested on locks with manf dates ranging from May 2014 to Mar 2025.

Safe companies like these

“[Securam] holds about 70% of the high-security smart lock systems market [...] with approximately 3 million customers in North America”

Dec. 2021; EastHouse tour by China National Hardware [...] Commercial Association



RHINO METALS™



Sources:

Manf and distributor websites

China National Hardware, Electrical and Chemical Products Commercial Association. (December 30, 2021).

Inspection of EastHouse. WeChat official account. (Note 3M includes all not just vulnerable products)ley. All rights reserved.

Companies selling SecuRam L01, L02, E66, OL66 and/or ScanLogic Basic

Ok but who else?
Anything Serious?

Pharmaceutical Safe Manufacturers



SecuRam
ProLogic



Used by some of **the largest commercial safe providers**

Trusted By: Hundreds of Canadian Pharmacies, Clinics and Business



Sources:

<https://narcsafe.com/>

<https://www.cennox.com/what-we-do/traditional-safes/>

Companies selling SecuRam L01, L02, E66, OL66 and/or ScanLogic Basic

SecuRam in the wild on Pharmacy Safes

2x Bonus
ProLogic



SecuRam
ProLogic



<https://www.wsaz.com/content/news/CVS-pharmacies-in-West-Virginia-added-time-delayed-safes-to-all-stores-566054271.html> @ 0:31

MR

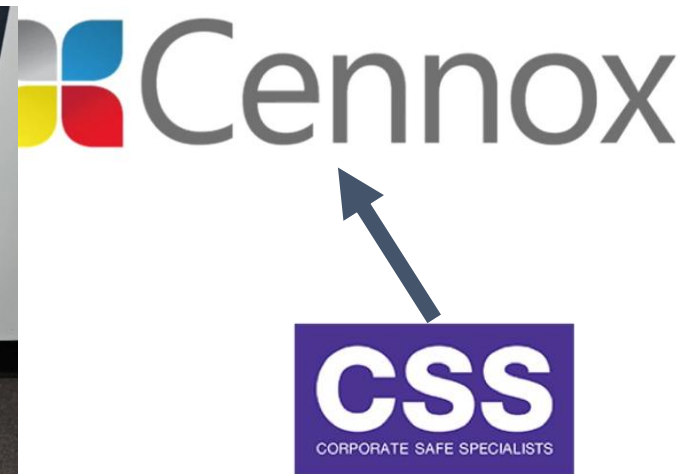
Also used in cash drop safes



Taco Del Mar



T-Mobile



Sources:
https://www.auctionfactory.com/archive_item_detail.php?item=103972
https://www.assetauctionsgroup.com/archive_item_detail.php?item=56310

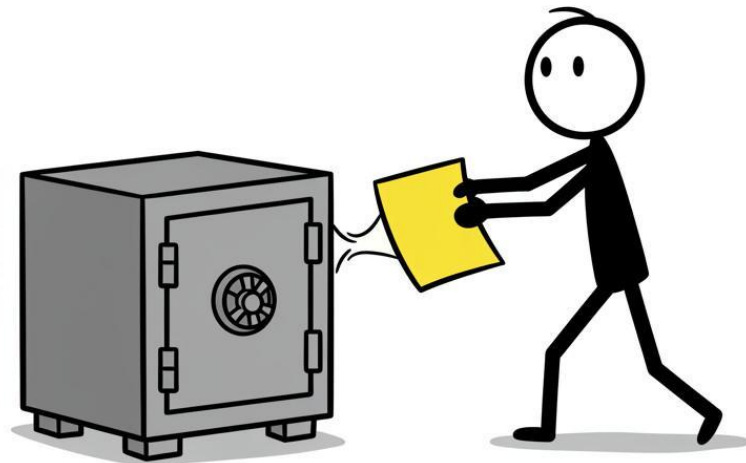
Mitigations

There are **no Mitigations** for existing users for CodeSnatch that we can identify, **except for SW update**

While going back and forth with SecuRam they sent us a lock with software “V6.00231223” (Presumably Dec 23 2023) that appeared to remove Keypad side code storage.

But we have not seen this version in the wild - a lock purchased a month ago (July 2025, made in March 2025) had a non-zero debug key, this does not effectively mitigate this attack.

We added this new value to our tool.



Sources:

Securam communication on Apr 27, 2024

Lock FW V6.00241217 (Dec 17th 2024)

Field Firmware Update

The Keypad and Latch **firmware**
can be updated in the field

Remember this tool?

It could be used to update the firmware in
the locks we examined!

An inexpensive service tool could be used
to update the firmware.



**But... Is there an
easier way in?**



Lock Recovery

Locks have this **Recovery** feature

“System **Recovery** is used to **delete all the codes** on the ProLogic or ScanLogic and set the Entrypad and its linked lock back to back to a factory default state”

“To Perform a Recovery, the Locksmith must call SECURAM, during business hours to speak with a live customer support representative.”

Sources:
<https://support.securamsys.com/hc/en-us/articles/6185820502043-ProLogic-Recovery>

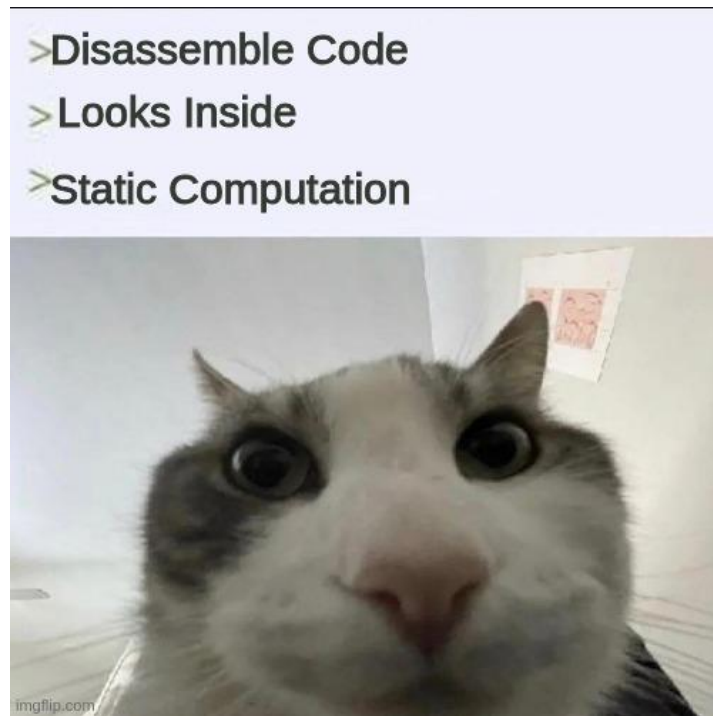
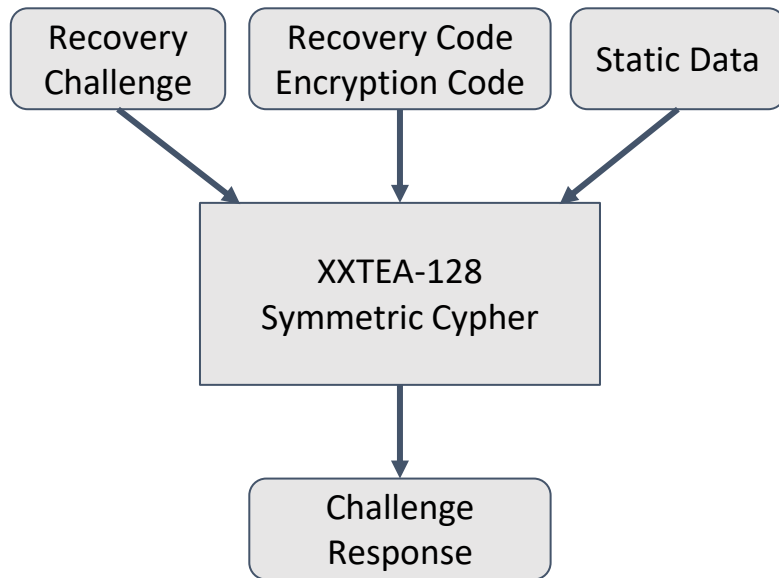
How Does it work?

- You enter the recovery code
 - (999999 by default)
- You are shown a recovery challenge
- You call Securam to get the correct response
 - (limited to registered Locksmiths)
- Type in the code
- All lock codes are reset



Sources:
<https://support.securamsys.com/hc/en-us/articles/6185820502043-ProLogic-Recovery>

I am sure this is implemented securely



Anyone can recover a lock

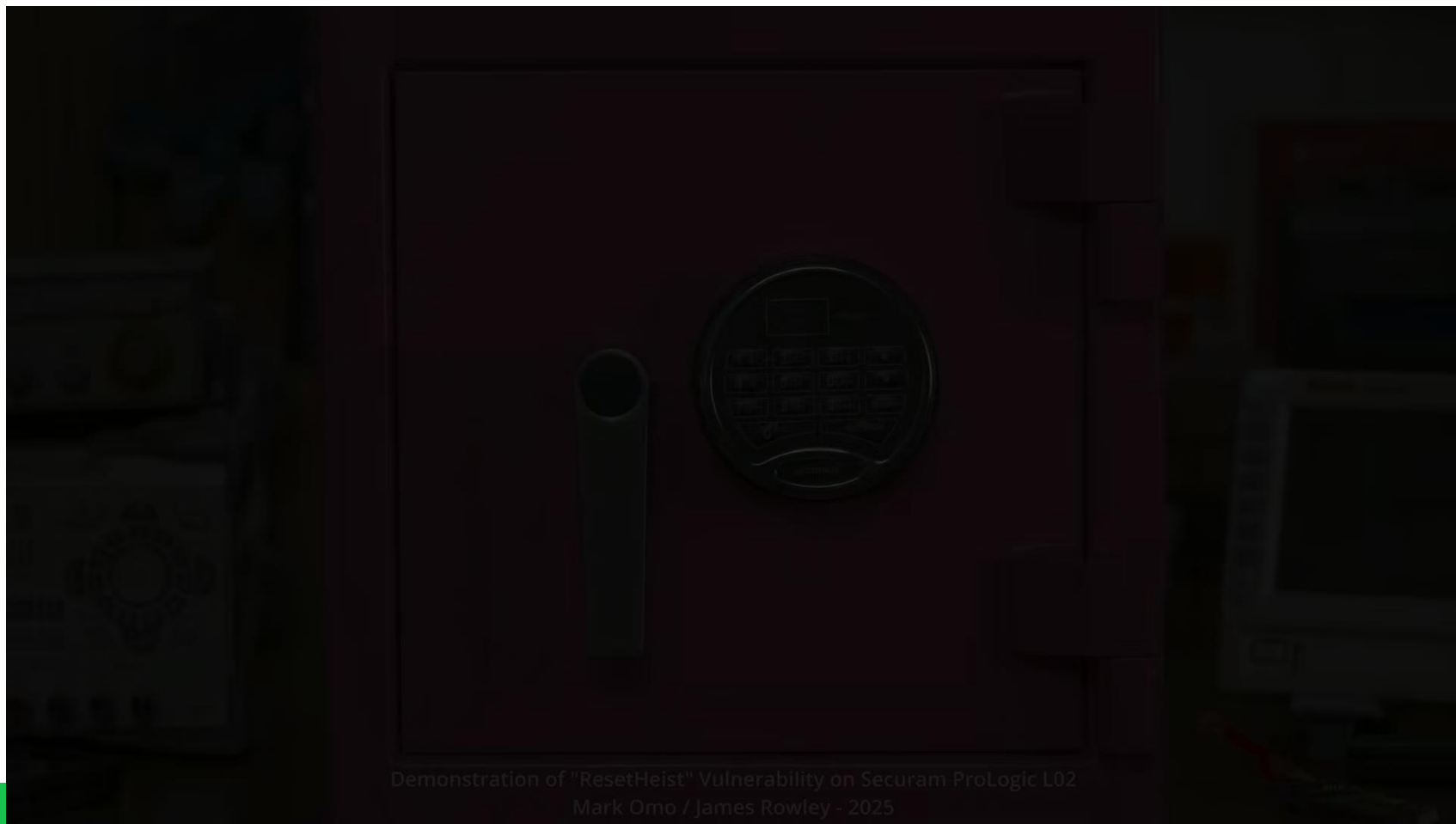
Source:
Analysis of "V6.00211027" firmware from EC-0601A-CL02-100LG
mfg'd in 2022 (S/N 4320A302210141601040)

Demo

“To Perform a Recovery,
the Locksmith must call
SECURAM [...]”



Demo (backup)



Demonstration of "ResetHeist" Vulnerability on Securam ProLogic L02
Mark Omo / James Rowley - 2025

What about Recovery/Encryption Code?

"Now, the **encryption key** is rarely **changed**, at least in the North American market. **No one ever changes this key**. You can change it. But most people leave it as default, and that's fine.

The **recovery code**, those six nines that we saw previously, is **also usually never changed** because there is **no security risk** in leaving as six nines as we saw previously. We have to decrypt that key. So, usually those things don't change."

Fix:

- Reprogram the Superfecta on a new EntryPad for replacement
 - Super Code
 - Encryption Key – usually never changed
 - Recovery Code – usually never changed
 - Device ID – usually never changed
- Replace the EntryPad and open using the known Super Code
- Reprogram all other features

However...

Some *printed* manuals do recommend changing recovery and encryption codes. Good!

We were unable to find this recommendation in any materials published online.

Secur

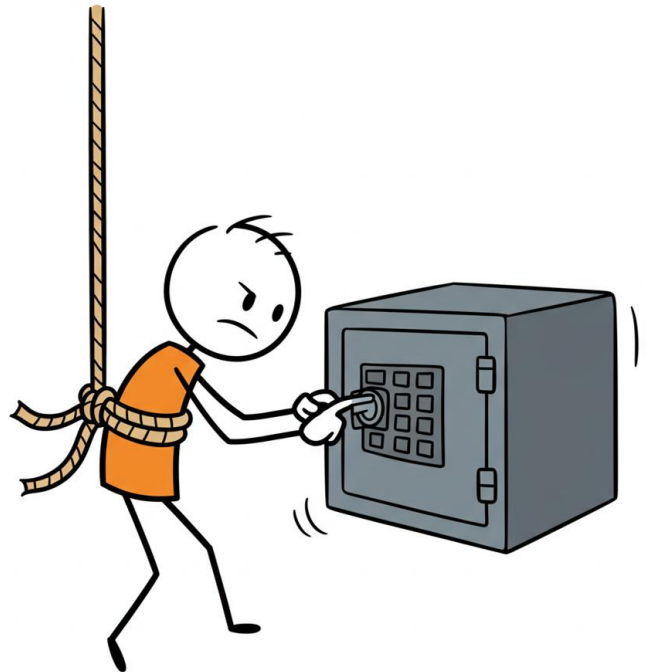
ResetHeist Mitigations

We call this attack
ResetHeist

It require **no tools or hardware**

You can **mitigate** ResetHeist
by **changing your Recovery Code and Encryption Code**

Changing the recovery code requires calling Securam





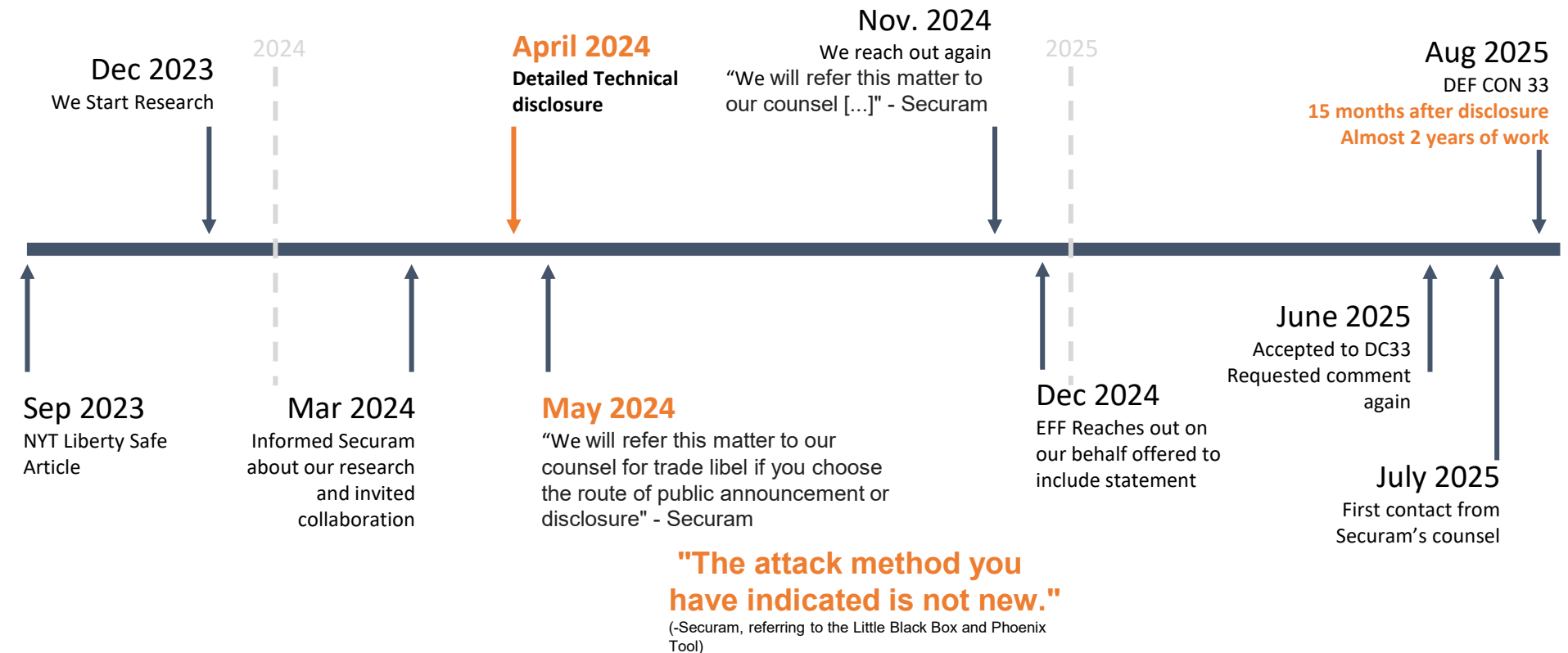
Confirmed Vulnerable Products

	Lock	CodeSnatch	ResetHeist
L01	EC-0601A-CL01-100LG - mfg'd Oct 2023 S/N 43427202310270005042/FW V6.00211027		
	EC-0601A-L02-C-II - mfg'd Mar 2025 S/N 43205392503210684057/FW V6.00241217		
	EC-0601A-CL02-100LG - mfg'd Sep 2024 S/N 43205392409201444056/FW V6.00231214		
L02	EC-0601A-CL02-100LG - mfg'd Oct 2022 S/N 4320A302210141601040/FW V6.00211027		
	EC-0601A-L02 - mfg'd Oct 2019 (Cennox SR2) S/N 22306361910251202045/FW V4.13180928		
	EC-0601A-L02 - mfg'd May 2014 S/N 19506091405141202050/FW V1.83130707		
	EC-0601A-E66-O - mfg'd Jul 2021 S/N 33406362107160085055/FW V4.12200930		
E66			
L66	EC-0601A-OL66 - mfg'd Jun 2021 S/N 23406362106250084052/FW V5.01200811		
ScanLogic Basic	FPC-1808-v5 (ScanLogic Basic) - mfg'd Dec 2023 S/N 51825392312220123051/FW V3.0220617 & V1.20190604		(Does not support recovery)

EVERY LOCK WE TESTED was vulnerable to ResetHeist.

Disclosure Timeline

Disclosure Timeline





Securam Communications

May 2024

“[...] **we don't believe it is appropriate [for you] to communicate to our customers of any concern.** Your disclosure to our customers would interfere with our relationship with the customers.”

“We object to your sharing or disclosure of your ‘findings’ even at a conference as such **disclosure** as you presented **would be misleading and damaging to SecuRam's goodwill and reputation.** We **will refer this matter to our counsel** for trade libel if you choose the route of public announcement or disclosure.”

Source:
Securam communication; May 3rd and 21st 2024
Emphasis added

Mitigation Timeline

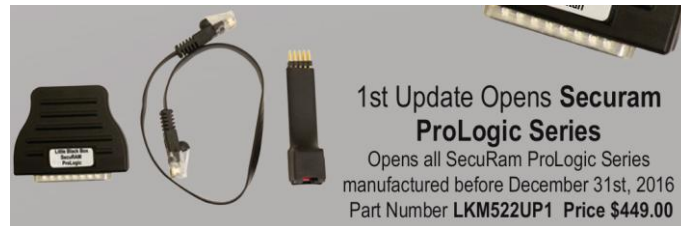
Securam did not share plans or timelines for mitigations with us.

Prior Art

Prior Art; “Locksmith only” tools

Little Black Box; tool that can open:

- **SecuRam**
 - Prologic models L01, B01, L02, L22, L62, L66 and L68 before Dec 16th 2016
- **LaGard**
 - LaGard Basic Series, 39E, and 66E up through mid-2018.
 - LG Basic, 33E, SafeGard 3600 & 3650, LgCombo from Jan. 2000 – Jan. 2016
- **Sargent & Greenleaf**
 - Sargent & Greenleaf 6120 locks from Jan. 2000 – Jan. 2016
 - S&G Spartan and Titan until February 2016
 - S&G 6123 Series Locks from 2000 until January 2016.
- **Amsec** locks
 - AMSEC – ESL5 & ESL15 series from 2000 to at least Feb. 2020
- **DormaKaba** locks
 - DormaKaba Auditcon 252 & 552 series until 2019



Phoenix Tool; another tool that can open:

- **AMSEC**
 - ESL-10, ESL-20
- **Sargent & Greenleaf**
 - 6120 ('98 - '13), 6121, 6123 ('98 - '13), Biometric, Titan PivotBolt *, Spartan PivotBolt **, Titan D-Drive *, Spartan D-Drive **
- **Sentry Safe**
 - SF Series
- **Lagard** locks
 - Basic/Basic Plus (through 2019), LGBasic (green board), LGBasic II (blue board through 2019), LGCombo, ComboGard 33E, SafeGard 3650, ComboGard Pro 39E, 3801, 3802, 4200, 3040, 3260, 3765, 3740, 2441 Mechanical Redundant, AuditGard 66E, LPAudit, LGAudit, 6441 Mechanical Redundant

Safe Locks with known exploited vulnerabilities

Would you use software with known vulns?

Sources:
<https://1010security.com/catalogsearch/result/?q=little%20Black%20Box>
<https://www.taylortechtools.com/phoenix>
 Private SecuRam communication

Prior Art; Others

- In 2016 Somerset recon demonstrated a Bluetooth sniffing attack against the ProLogic B01, resulting in unlock capability
- Separately, they demonstrated a rapid unlock capability against a ECSL-0601A latch unit using a specialized tool
- Deviant Ollam's talk on locksmith tools (among other things) at PancakeCon 2024: [youtube.com/watch?v=mi3Wlwq86t8](https://www.youtube.com/watch?v=mi3Wlwq86t8)

Sources:

<https://www.somersetrecon.com/blog/2016/10/14/electronic-safe-lock-analysis-part-2->

<https://www.youtube.com/watch?v=hOZkViOOiKE>

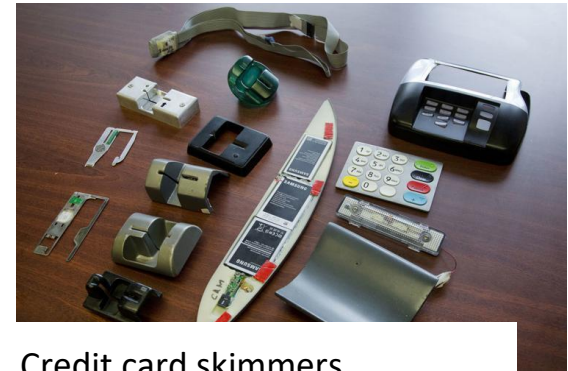
Summary and Takeaways

Our opinions on lock safety

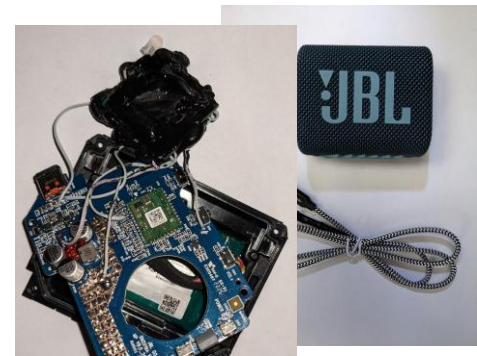
Does it really matter?

Is this a **legitimate threat** to security?

- **Yes** - organized crime rings could make this tool, or do the reset thing
 - They **already make credit card skimmers**
 - And sell and use **tools to steal cars** via CAN hacking
- So could nation-state threat actors.
- **Quick to open means it's actually practical**



Credit card skimmers



Tool to steal cars via CAN Bus

Sources:

<https://apnews.com/general-news-e254277cefa44657a2427ec0aa93999b>

<https://www.designworldonline.com/skim-reaper-detecting-credit-card-skimmers-one-swipe-at-a-time/>

<https://kentindell.github.io/2023/04/03/can-injection/>

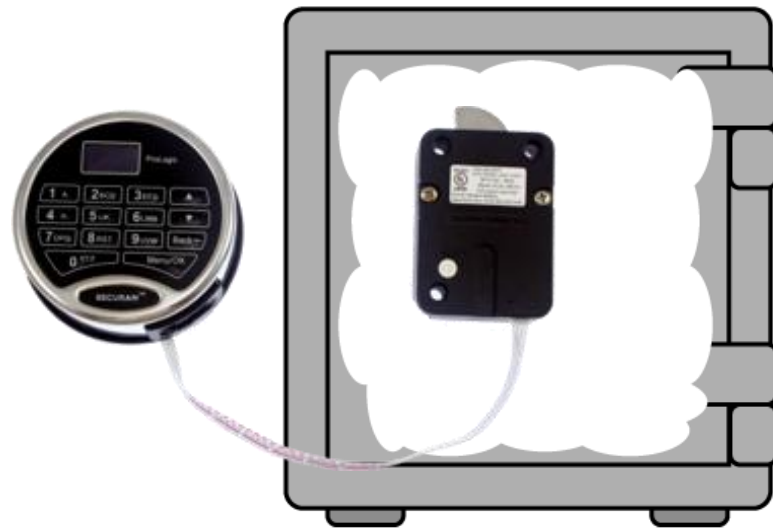
Threat Modeling

The **codes** need to be **inside the safe**

- (Safes are designed to protect the inside)

Anything else can become a weak point

Safe codes are generally short (6-8 digits, 20-25 bit of security) **hashing is ineffective**



What Went Wrong?

Where was the biggest failure?

- Securam for it's design?
- Safe OEMs for not vetting it?
- UL..?

Almost...

Standards for electronic physical security products
lag significantly behind the state of the art

You should be able to trust the certification



Certified Locks

Little Black Box:

- **SecuRam**
 - Prologic models L01, B01, L02, L22, L62, L66 and L68 before Dec 16th 2016
- **LaGard**
 - LaGard Basic Series, 39E, and 66E
 - LG Basic, 33E, SafeGard 3600 & 3650, LgCombo
- **Sargent & Greenleaf**
 - Sargent & Greenleaf 6120 locks
 - S&G Spartan and Titan
 - S&G 6123 Series Locks
- **Amsec locks**
 - AMSEC – ESL5 & ESL15 series
- **DormaKaba locks**
 - DormaKaba Auditcon 252 & 552 series

Locks that are UL Type 1
certified

Phoenix Tool:

- **AMSEC**
 - ESL-10, ESL-20
- **Sargent & Greenleaf**
 - 6120, 6121, 6123, Biometric, Titan PivotBolt, Spartan PivotBolt, Titan D-Drive, Spartan D-Drive
- **Sentry Safe**
 - SF Series
- **Lagard locks**
 - Basic/Basic Plus, LGBasic, LGBasic II, LGCombo, ComboGard 33E, SafeGard 3650, ComboGard Pro 39E, 3801, 3802, 4200, 3040, 3260, 3765, 3740, 2441 Mechanical Redundant, AuditGard 66E, LPAudit, LGAudit, 6441 Mechanical Redundant

Sources:
UL: <https://productiq.ulprospector.com/en>

Certification - Looking Forward

Should require:

- Secure Product Development Framework (SPDF)
- Threat Modeling/Risk Assessment
- Detailed flow and functional descriptions
- Independent white box/black box cybersecurity testing
- FIPS/Common Criteria type side channel testing

Following examples from:

- Medical device field/FDA
 - FDA; Cybersecurity in Medical Devices
 - IEC 81001-5-1; Health software systems safety, effectiveness and security
- Automotive field/NHTSA
 - NHTSA; Cybersecurity Best Practices for the Safety of Modern Vehicles
 - ISO/SAE 21434; Road vehicles — Cybersecurity engineering



Bonus; Chinese Government Backdoors

There been been a lot of hype in the media about Chinese government mandated backdoors

We found no evidence of any such feature in any locks we examined
(except for those in the manual)

Don't believe the hype

Bad Design ≠ Government Backdoors

EFF / Coder's Rights Project

Big thanks to the EFF's Coder's Rights Project for representing us!

They helped us understand our rights and our exposure, and gain the confidence to disclose this important information.

Questions?